Zero Trust

Quick briefing

Zero trust evaluates each session against resource-specific policy using verified identity, device state and other relevant context.

Know the facts

Zero trust and ZTA · Zero trust is the approach. A zero trust architecture (ZTA) is the enterprise plan that applies it to resources and workflows.

Per-session least privilege · Authorize only the resources and permissions needed for the session. Reassess access as policy or relevant conditions change.

Policy decision point · The Policy Engine decides whether to grant, deny or revoke access. The Policy Administrator carries out that decision by setting up or shutting down the connection path.

Policy Enforcement Point · The PEP enables, monitors and terminates the connection according to the policy decision.

Deployment approaches · Enhanced identity governance, micro-segmentation and software-defined perimeter approaches can coexist.

Control-plane risk · Policy components are critical dependencies. Misconfiguration can allow inappropriate access, and outages can interrupt legitimate work.

Understand the reasoning

Successful authentication identifies a subject. Authorization still depends on the requested resource, device state and what the subject needs to do.

Start with a small workflow and observe legitimate access patterns. That makes it easier to discover exceptions before enforcement disrupts a critical service.

Philippine Army classroom exercise

A fictional Philippine Army school's training portal can serve staff from managed and personal devices. The pilot team finds that a small number of staff need to upload grades, while most users only read course notices.

Decision · How should the team define pilot access and check whether the policy works?

Worked analysis · Define separate access to notices and grade uploads based on the user's role and device state. Observe legitimate sessions in a pilot to verify that instructors can do their work and readers are limited to notices. Check how the portal behaves when its policy service becomes unavailable before expanding the rollout.

How to practice

1 · Inventory the users, service identities, devices and resources involved in one low-risk classroom workflow.

2 · Map legitimate actions to the minimum permissions and device conditions each action requires.

3 · Select a pilot enforcement point and observe requests in reporting-only mode where available.

4 · Compare proposed access decisions with authorized use, refine the policy and test service availability.

5 · Enforce the validated policy for the pilot and monitor for unexpected denials and grants.

Check yourself

Which component grants, denies or revokes access according to policy? · The Policy Engine.

Which component enforces the decision at the connection to the resource? · The Policy Enforcement Point.

Course source

Zero Trust · SOAC Lesson